

Security Architecture

Security Summary

The platform uses Microsoft Entra ID for identity, app roles for administration, application roles for HRBP and PayrollBP workflows, tenant-scoped data access, managed identities for Azure resource access, Key Vault for secrets, and Front Door WAF for edge protection.

Identity Architecture

Authentication is based on Microsoft Entra ID OAuth2/OIDC access tokens.

Backend validation:

1. Extract bearer token.
2. Decode unverified claims to read `tid`.
3. Resolve `tid` to a registered tenant.
4. Fetch the signing key from Microsoft JWKS.
5. Verify signature with RS256.
6. Verify expected issuer `https://login.microsoftonline.com/{tid}/v2.0`.
7. Verify expected audience equals `CLIENT_ID`.
8. Extract UPN, preferred username, or email.
9. Resolve user in the tenant roster.

The `/common` authority supports multi-tenant login, while application logic restricts access to registered tenants only.

Authorization Model

Access	Authorization source
Standard nomination features	Authenticated user in tenant roster.
Manager approvals	<code>Nominations.ApproverId</code> equals effective user ID.
HRBP review	<code>UserRoles</code> contains <code>HRBP</code> for effective user.
Payroll lookup	<code>UserRoles</code> contains <code>PayrollBP</code> for effective user.
Admin analytics and audit	Entra app role <code>Award_Nomination_Admin</code> or <code>Administrator</code> .
Admin impersonation	Entra admin role, tenant-scoped target user.
Internal callbacks	<code>X-Internal-Key</code> shared secret.
Service Bus send/receive	Managed identity RBAC.

Tenant Isolation

Tenant isolation is enforced by:

- Entra tenant allowlist in `Tenants`.
- User lookup by UPN/email and internal `TenantId`.
- Tenant-scoped SQL helper methods.

- Domain lookup for public branding.
- Wrong-domain protection in the frontend.
- Tenant-specific categories and config.
- Cross-tenant impersonation prevention.
- Tenant checks in HRBP and nomination access paths.

Security recommendation: add database-level row-level security for defense in depth if enterprise tenants require stronger isolation guarantees.

Admin Impersonation Security

Admin impersonation behavior:

- Only actual admin token roles are used to authorize impersonation.
- Target user must exist in the same tenant.
- Effective user changes for business workflow actions.
- Actual user remains the identity for admin-only checks.
- Impersonated user does not inherit admin roles.
- Impersonation start and workflow actions are logged.

Risk: impersonation is powerful and should be restricted to tenant support and audit scenarios.

Recommended controls:

- Require a business reason for impersonation.
- Alert on impersonation sessions.
- Include IP address and user agent when available.
- Review audit logs regularly.

Secrets Management

Secrets are stored in Azure Key Vault and referenced by container apps/jobs.

Examples:

- SQL credentials.
- Application Insights connection strings.
- Azure OpenAI keys and endpoint.
- Storage keys.
- SMTP password.
- Webhook secrets.
- Payroll provider client secrets.
- Payroll token encryption key.
- Internal callback secrets.

Terraform attaches user-assigned managed identities before Key Vault-backed container app secrets are resolved. This avoids identity creation race conditions.

Azure Resource Access

Managed identity is preferred for Azure resource access.

Resource	Access pattern
Service Bus	Data Sender/Data Receiver roles scoped to topic or namespace.
Key Vault	Access policies for user-assigned identities.
Blob Storage	Storage credentials and/or managed identity depending on component.
Azure SQL	SQL credentials today; some comments indicate managed identity SQL contained users for jobs.
Application Insights	Connection strings from Key Vault.

Service Bus Terraform sets `local_auth_enabled = false`, disabling SAS keys and connection strings.

Network and Edge Security

Edge controls:

- Azure Front Door Standard.
- WAF policy in Prevention mode.
- HTTPS redirect.
- Health probes to `/health`.
- TLS 1.2 minimum for Front Door custom domains.
- Separate Front Door route for payroll broker custom domain.
- CORS rules at Front Door and backend.

Network controls:

- Container Apps environments are VNet injected.
- SQL, Storage, Key Vault, OpenAI, ACR modules include private endpoint patterns.
- Premium Service Bus can use private endpoint when SKU supports it.

API Security Controls

- JWT token validation on protected endpoints.
- Role dependencies for admin endpoints.
- HRBP role dependency for HRBP endpoints.
- PayrollBP check for payroll endpoint.
- Pydantic validation for request payloads.
- Tenant-scoped lookup before sensitive operations.
- Signed token for email action approval/rejection links.
- Validation error flattening to avoid leaking full internal structures to frontend.

Service Bus Security Controls

- Managed identity RBAC.
- Local auth disabled in Terraform.
- Topic subscription filters isolate consumers.
- Message lock and max delivery handling.
- Dead-letter behavior for invalid JSON or max delivery failures.
- Idempotency via `ProcessedEvents`.

- Trace context propagation through application properties.

Payroll Security

Payroll integration carries higher sensitivity.

Controls present:

- PayrollBP role gates payroll lookup.
- Payroll tokens are stored in `payroll_tokens`.
- Token encryption key is provided through Key Vault.
- Provider webhook secrets are stored in Key Vault.
- Payroll broker has separate Front Door route and WAF association.
- Payroll broker provider registry isolates provider implementation.

Recommended additions:

- Enforce tenant check when resolving payroll lookup target user by ID.
- Mask payroll profile fields in logs.
- Add explicit audit log for PayrollBP lookups.
- Add least-privilege provider scopes per tenant.

Threat Model Summary

Threat	Mitigation
Token replay from unregistered tenant	Tenant allowlist and issuer validation.
Cross-tenant data access	Tenant ID in auth context and query filters.
Admin privilege misuse	App role checks, impersonation auditing, tenant-scoped impersonation.
Duplicate event side effects	<code>ProcessedEvents</code> idempotency.
Secret exposure	Key Vault references and managed identity.
Service Bus key leakage	Local auth disabled.
Public endpoint attacks	Front Door WAF, HTTPS, CORS restrictions.
Payroll webhook spoofing	Provider webhook secrets.
Model overreach	HRBP human review and explainable flags.

Security Recommendations

- Add database row-level security.
- Add centralized audit table for all privileged operations, not only impersonation.
- Add payroll lookup audit logging.
- Store model artifact metadata and checksums.
- Add vulnerability scanning to CI/CD.
- Add dependency license and CVE review.
- Add security headers for frontend.
- Define tenant offboarding data deletion process.
- Define incident response runbooks for auth, payroll, and data exposure events.